

Security+ 3.2 · Port Security

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 3.2 — Port Security (3:50)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: 802.1X authenticates the user or machine before granting network access at the switch port. RADIUS centralizes AAA (Authentication, Authorization, Accounting). Without 802.1X, anyone can connect and gain access. NAC (Network Access Control) extends 802.1X with posture checks (antivirus, patch health).

High-Yield Core Concepts Tested on Exam

- 802.1X: authenticates BEFORE granting access to the switch port
- RADIUS: the centralized backend for AAA
- NAC: 802.1X + health/posture checks (antivirus, patch level)
- Without 802.1X, any device can connect and gain network access
- 802.1X operates at the port level (Layer 2)

Exam Tips & Classic Scenarios

- 'requires authentication before network access' = 802.1X
- 'switch requires login before allowing traffic' = 802.1X + RADIUS

Typical Exam Scenario: A switch requires authentication before allowing any traffic on a port. This is 802.1X, typically backed by a RADIUS server for centralized AAA.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 3.2 — Port Security)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **TACACS+:** Terminal Access Controller Access-Control System Plus: Enterprise AAA protocol running over TCP port 49; fully encrypts the entire packet payload and decouples authentication from authorization, enabling granular per-command control on network switches and routers.
- **RADIUS:** Remote Authentication Dial-In User Service: Client/server AAA protocol (UDP ports 1812/1813) standard in 802.1X and VPN environments; encrypts only the password field and combines authentication and authorization.
- **802.1X:** IEEE standard for Port-Based Network Access Control (PNAC). Restricts unauthorized network access at the physical port or wireless layer until credentials are authenticated via RADIUS.
- **KERBEROS:** Default Active Directory authentication protocol based on symmetric ticket granting issued by the Key Distribution Center (KDC: AS and TGS), preventing cleartext credentials on the wire.
- **LDAP:** Lightweight Directory Access Protocol: Protocol for querying centralized directory services (cleartext over TCP port 389).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Service that centralizes network access authentication (login to switch/VPN via central server):

- A) RADIUS**
- B) DNS**
- C) SMTP**
- D) NTP**

2. Manages services (start/stop/status) in modern Linux:

- A) systemctl**
- B) service (old)**
- C) initd**
- D) runlevel**

3. Which authentication protocol uses tickets and is widely used in Active Directory environments?

- A) RADIUS**
- B) TACACS+**
- C) Kerberos**
- D) LDAP**

4. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: '802.1X: authenticates BEFORE granting access to the switch port'. What is the best recommendation or applicable control classification?

- A) Implement the corresponding solution: 802.1X: authenticates BEFORE granting access to the switch port...**
- B) Temporarily disable audit logs to accelerate system throughput**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

5. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'RADIUS: the central AAA backend'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: RADIUS: the central AAA backend...
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'NAC: 802.1X + health check (antivirus, patch)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: NAC: 802.1X + health check (antivirus, patch)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'requires authentication before network access'=802.1X'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'requires authentication before network access'=802.1X...

8. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 3.2) exam, an analyst evaluates the following technical requirement: 'switch requires login before allowing traffic'=802.1X + RADIUS.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'switch requires login before allowing traffic'=802.1X + RADIUS....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: '802.1X: authenticates BEFORE granting access to the switch port'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 802.1X: authenticates BEFORE granting access to the switch port...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Port Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'RADIUS: the central AAA backend'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: RADIUS: the central AAA backend.

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — RADIUS.

✓ **Why it is correct:** RADIUS (Remote Authentication Dial-In User Service) is an authentication, authorization, and accounting (AAA) protocol that centralizes network access control. Access devices such as switches, routers, VPNs, and wireless access points act as RADIUS clients and forward user credentials to a central RADIUS server. This server verifies credentials against a directory (e.g., Active Directory, LDAP) and returns an accept or reject decision, along with authorization attributes (e.g., VLAN, session timeout). This allows consistent access policy management across the infrastructure without configuring local accounts on each device.

✗ **Why the others are wrong:**

- *DNS*: DNS (Domain Name System) is a name resolution service that translates human-readable domain names (e.g., `www.example.com`) into IP addresses. It does not authenticate users, manage access sessions, or centralize credentials. Although DNSSEC exists to authenticate DNS responses, that is security of the protocol itself, not a network access authentication mechanism for users or devices. Therefore, DNS does not meet the requirement of centralizing login on switches or VPNs.
- *SMTP*: SMTP (Simple Mail Transfer Protocol) is the standard protocol for sending and transferring email messages between servers. It handles asynchronous email communication, not network access authentication. Although SMTP AUTH exists for sending emails, it applies to the email service itself, not to access control for switches, VPNs, or other network equipment. Therefore, it is completely inapplicable to the described scenario.
- *NTP*: NTP (Network Time Protocol) is used to synchronize device clocks on a network with a trusted time source. Precise synchronization is important for forensic logs, certificate validity, and time-based authentication protocols (such as Kerberos), but NTP itself does not authenticate users or centralize network access. It does not receive credentials, query directories, or make authorization decisions. Therefore, it does not replace a RADIUS server.

2) A — `systemctl`.

✓ **Why it's correct:** `systemctl` is the primary command of `systemd`, the default init system and service manager in most modern Linux distributions (RHEL 7+, Ubuntu 15.04+, Debian 8+, CentOS 7+, etc.). It allows starting, stopping, restarting, reloading, enabling, disabling, and checking the status of service units, sockets, devices, and mount points. The question asks for the service manager in modern Linux, and `systemctl` is the canonical tool for this function, being the de facto industry standard.

✗ **Why the others are wrong:**

- *service (old)*: The `service` command is a legacy wrapper for SysVinit that still exists on some systems for compatibility, but it is not the native manager in modern Linux. It runs init scripts in `/etc/init.d/` and lacks features like explicit dependencies, socket activation, cgroups, or log journaling. In modern distributions, `service` often redirects to `systemctl`, but by itself it does not represent the current service management tool. The question asks for the manager in modern Linux, and `service` is considered obsolete for this purpose.
- *initd*: `initd` (or SysVinit) is the traditional init system based on sequential scripts located in `/etc/init.d/` and runlevels. It has been largely replaced by `systemd` because it is slower, does not manage dependencies efficiently, and lacks features like parallelization, resource control, or centralized logging. It is not a service management command in modern Linux, but rather the old init system itself. The question asks for the management tool, and `initd` is not a command but the legacy architecture.
- *runlevel*: `runlevel` is a concept from SysVinit that defines the operational state of the system (e.g.,

0 = shutdown, 1 = single-user, 3 = multi-user with network, 5 = graphical). The runlevel command displays the previous and current runlevel, but does not manage individual services (start/stop/status). It is a remnant of the old model and does not offer granular control over service units. Therefore, it does not meet the requirement of managing services in modern Linux, being only an informational utility of the legacy system.

3) C — Kerberos.

✓ **Why it's correct:** **Kerberos** is a ticket-based authentication protocol widely used in Microsoft Active Directory (AD) environments. It uses symmetric cryptography and a Key Distribution Center (KDC) to authenticate users and services without transmitting passwords over the network. The process involves obtaining a Ticket Granting Ticket (TGT) and subsequently service tickets to access resources. In the CompTIA Security+ (SY0-701) syllabus, Kerberos is highlighted as the default authentication protocol in Windows domains, offering mutual authentication and single sign-on (SSO) support. The mention of 'tickets' and 'Active Directory' points directly to Kerberos.

✗ **Why the others are wrong:**

- **RADIUS:** RADIUS (Remote Authentication Dial-In User Service) is an authentication, authorization, and accounting (AAA) protocol used primarily for remote network access, such as VPNs, corporate Wi-Fi, and dial-up connections. It does not use tickets; instead, it employs a client-server model with attributes and challenges (such as PAP, CHAP, EAP). Although it can integrate with Active Directory to validate credentials, it is not the native AD authentication protocol and is not ticket-based. Therefore, it does not match the description.
- **TACACS+:** TACACS+ (Terminal Access Controller Access-Control System Plus) is an AAA protocol developed by Cisco, used for authentication, authorization, and accounting of network devices (routers, switches). It separates AAA functions and encrypts the entire payload, but does not use tickets and is not the default authentication mechanism for Active Directory. Its focus is managing access to infrastructure equipment, not authenticating users in Windows domains. Thus, it is incorrect for the presented context.
- **LDAP:** LDAP (Lightweight Directory Access Protocol) is a protocol for accessing directory services, such as Active Directory, allowing queries and modifications to objects (users, groups, computers). It is used for reading and writing to the directory, but is not a ticket-based authentication protocol. Authentication in AD typically occurs via Kerberos or NTLM; LDAP can be used for simple authentication (bind), but does not employ tickets and is not the primary authentication mechanism in AD environments. Therefore, it does not meet the 'uses tickets' description.

4) A — Implement the corresponding solution: 802.1X: authenticates BEFORE granting access to the switch port....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): 802.1X: authenticates BEFORE granting access to the switch port. 802.1X is a port-based network access control that requires authentication before allowing access to the network.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: RADIUS: the central AAA backend....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): RADIUS: the central AAA backend.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: NAC: 802.1X + health check (antivirus, patch)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): NAC: 802.1X + health check (antivirus, patch).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'requires authentication before network access'=802.1X....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): 'requires authentication before network access'=802.1X.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'switch requires login before allowing traffic'=802.1X + RADIUS.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): 'switch requires login before allowing traffic'=802.1X + RADIUS. IEEE 802.1X is a port-based network access control standard that requires authentication before granting network access, typically using a RADIUS server as the authentication backend.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 802.1X: authenticates BEFORE granting access to the switch port....

✓ **Why it's correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 3.2 (Port Security): 802.1X: authenticates BEFORE granting access to the switch port.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

10) D — Implement the corresponding solution: RADIUS: the central AAA backend..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Port Security): RADIUS: the central AAA backend. RADIUS provides centralized Authentication, Authorization, and Accounting (AAA) for network access, commonly used with 802.1X for port-based authentication. It ensures consistent policy enforcement and auditing.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

